

Section No.	Section Name	Category	Question	Response (Yes/No/Partial)
				Dropdown for Questions
1	General Information	General Info	Application / Process Name	Text
		General Info	Briefly describe the business process, application, or solution, including its purpose and how personal data is collected, used, stored, shared, and disposed of.	Text
		General Info	Department / Business Unit	Text
		General Info	Process Owner / Contact	Text
		General Info	Assessment Date	Text
		General Info	Linked DPIA / ROPA Reference	Text
		General Info	Reviewed By (DPO / Legal)	Text
		General Info	Next Review Date	Text
2	Design & Planning Phase	Design	Have privacy requirements been identified and documented as part of the solution design? (Technical & Organizational Measures)	(Yes/No/Partial)
		Design	Have applicable privacy laws and contractual obligations been identified and considered during solution design? (GDPR, HIPAA, DPDPA, CCPA etc).	(Yes/No/Partial)
		Design	Is Privacy by Design (PbD) integrated into the Software Development Life Cycle (SDLC) or project lifecycle?	(Yes/No/Partial)
		Design	Has it been determined whether a DPIA or other privacy assessment is required?	(Yes/No/Partial)

Justification for No/NA	Evidence Upload & View	GDPR / ISO / Law Reference	Risk Level	Responsible Person
		Dropdown (Low/Medium/High)		
BLANK				Text
				Text
				Text
				Text
				Text
				Text
				Text
				Text
		GDPR: Art. 25(1), Art. 32 • DPDPA: Section 8 (Obligations of Data Fiduciary – Security Safeguards) • HIPAA: 45 CFR §164.306, §164.308 • CCPA/CPRA: §1798.100, §1798.185 • ISO/IEC 27701: A.7.4.1	(Low/Medium/High)	Text
		GDPR: Art. 24, Art. 28 • DPDPA: Section 8 • HIPAA: 45 CFR §164.308(a)(1), §164.504(e) • CCPA/CPRA: §1798.100, §1798.140, §1798.145 • ISO/IEC 27701: A.7.2.1, A.7.2.8	(Low/Medium/High)	Text
		GDPR: Art. 25, Art. 24 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.308(a)(1), §164.306 • CCPA/CPRA: Reasonable Security; Risk Assessment Requirements • ISO/IEC 27701: A.7.4.1, A.7.5.1	(Low/Medium/High)	Text
		GDPR: Art. 35, Art. 36 • DPDPA: Good Practice (Risk Assessment; Significant Data Fiduciary obligations where applicable) • HIPAA: 45 CFR §164.308(a)(1)(ii)(A) (Risk Analysis) • CCPA/CPRA: Risk Assessment Requirements • ISO/IEC 27701: A.7.2.5	(Low/Medium/High)	Text

		Design	If Applicable, has a Data Protection Impact Assessment (DPIA) or equivalent privacy assessment been completed before implementation	(Yes/No/Partial)
		Design	Have personal data flows and processing activities been identified and documented (e.g., for ROPA) before implementation or go-live?	(Yes/No/Partial)
		Design	Have risk assessments considered emerging tech (AI, IoT, ML)?	(Yes/No/Partial)
		Design	Has a privacy review been completed before development or implementation begins?	(Yes/No/Partial)
3	Data Collection & Minimization	Collection	Is personal data collection limited to what is necessary?	(Yes/No/Partial)
		Collection	Are optional fields clearly distinguished from mandatory ones?	(Yes/No/Partial)
		Collection	Are special category data avoided unless necessary?	(Yes/No/Partial)
		Collection	Is the lawful basis identified and documented for personal data processing?	(Yes/No/Partial)
		Collection	Has data minimization been verified during the design/review?	(Yes/No/Partial)

		GDPR: Art. 35, Art. 36 • DPDPA: Good Practice (Risk Assessment; Significant Data Fiduciary obligations where applicable) • HIPAA: 45 CFR §164.308(a)(1)(ii)(A) (Risk Analysis) • CCPA/CPRA: Risk Assessment Requirements • ISO/IEC 27701: A.7.2.5	(Low/Medium/High)	Text
		GDPR: Art. 30 • DPDPA: Section 10 (Significant Data Fiduciary, where applicable) • HIPAA: 45 CFR §164.316 • CCPA/CPRA: §1798.100 • ISO/IEC 27701: A.7.2.6	(Low/Medium/High)	Text
		GDPR: Art. 25, Art. 35 • DPDPA: Section 8 (Security Safeguards) • HIPAA: 45 CFR §164.308(a)(1)(ii)(A) • CCPA/CPRA: Risk Assessment Requirements • ISO/IEC 27701: A.7.4.2	(Low/Medium/High)	Text
		GDPR: Art. 25 • DPDPA: Section 8 • HIPAA: 45 CFR §164.308(a)(8) (Evaluation) • CCPA/CPRA: §1798.100 • ISO/IEC 27701: A.7.5.1	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(c), Art. 25 • DPDPA: Sec. 4, Sec. 8 • HIPAA: 45 CFR §164.502(b) (Minimum Necessary) • CCPA/CPRA: §1798.100 • ISO 27701: A.7.2.2, A.7.4.1	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(c), Art. 25 • DPDPA: Sec. 4 • HIPAA: Minimum Necessary Principle • CCPA/CPRA: §1798.100 • ISO 27701: A.7.2.2	(Low/Medium/High)	Text
		GDPR: Art. 9, Art. 25 • DPDPA: Sec. 4, Sec. 8 • HIPAA: Privacy Rule • CCPA/CPRA: Sensitive Personal Information (§1798.121) • ISO 27701: A.7.2.8	(Low/Medium/High)	Text
		GDPR: Art. 6, Art. 9 • DPDPA: Sec. 4–7 • HIPAA: Privacy Rule (Permitted Uses & Disclosures) • CCPA/CPRA: §1798.100 • ISO 27701: A.7.2.1	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(c), Art. 25 • DPDPA: Sec. 8 • HIPAA: Minimum Necessary Principle • CCPA/CPRA: Data Minimization Principle • ISO 27701: A.7.4.1	(Low/Medium/High)	Text

Text

Text

Text

Text

Text

Text

Text

Text

Text

		Collection	Are mechanisms provided to keep personal data accurate and up to date, where applicable?	(Yes/No/Partial)
		Collection	Is personal data processed only for the specified, explicit, and legitimate purposes for which it was collected?	(Yes/No/Partial)
4	Transparency & User Rights	Transparency	Is a privacy notice provided before or at the time of data collection?	(Yes/No/Partial)
		Transparency	Are users informed about the purpose of processing and data retention?	(Yes/No/Partial)
		Transparency	Are Data Subject Rights (Access, Correction, Erasure, etc.) supported through documented processes and system capabilities?	(Yes/No/Partial)
		Transparency	Can users easily withdraw their consent, where applicable?	(Yes/No/Partial)
		Transparency	Is consent management implemented in a clear, fair, and non-misleading manner, avoiding dark patterns?	(Yes/No/Partial)
		Default	Are default privacy settings configured to provide the highest level of privacy without requiring user action? (e.g., profiles set to private by default, optional cookies disabled where applicable)	(Yes/No/Partial)
		Default	Is only the minimum necessary personal data shared by default?	(Yes/No/Partial)

		GDPR: Art. 5(1)(d), Art. 16 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.526 • CCPA/CPRA: §1798.106 • ISO 27701: A.7.3.3	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(b), Art. 6 • DPDPA: Sec. 5, Sec. 8 • HIPAA: 45 CFR §164.502 • CCPA/CPRA: §1798.100 • ISO 27701: A.7.2.1	(Low/Medium/High)	Text
		GDPR: Art. 12, 13, 14 • DPDPA: Sec. 5 • HIPAA: 45 CFR §164.520 (Notice of Privacy Practices) • CCPA/CPRA: §1798.100, §1798.130 • ISO 27701: A.7.3.2	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(b), Art. 13, 14 • DPDPA: Sec. 5 • HIPAA: 45 CFR §164.520 • CCPA/CPRA: §1798.100 • ISO 27701: A.7.3.2	(Low/Medium/High)	Text
		GDPR: Art. 15–22 • DPDPA: Sec. 11–13 • HIPAA: 45 CFR §164.524, §164.526 • CCPA/CPRA: §1798.105, §1798.106, §1798.110 • ISO 27701: A.7.3.3	(Low/Medium/High)	Text
		GDPR: Art. 7(3) • DPDPA: Sec. 6 • HIPAA: Authorization Revocation (45 CFR §164.508) • CCPA/CPRA: Right to Opt-Out (§1798.120) • ISO 27701: A.7.2.4	(Low/Medium/High)	Text
		GDPR: Art. 4(11), Art. 7, Art. 25 • DPDPA: Sec. 6 • HIPAA: 45 CFR §164.508 • CCPA/CPRA: Consent & Dark Pattern Rules (§1798.140, CPRA Regulations) • ISO 27701: A.7.2.4	(Low/Medium/High)	Text
		GDPR: Art. 25(2) • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.306 • CCPA/CPRA: §1798.100 • ISO 27701: A.7.4.1	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(c), Art. 25(2) • DPDPA: Sec. 4, Sec. 8 • HIPAA: 45 CFR §164.502(b) (Minimum Necessary) • CCPA/CPRA: §1798.100 • ISO 27701: A.7.4.1	(Low/Medium/High)	Text

Text

Text

Text

Text

Text

Text

Text

Text

Text

5	Default Privacy Settings	Default	Are additional privacy safeguards applied when processing children's personal data, where applicable?	(Yes/No/Partial)
		Default	Are data sharing options disabled by default unless the user explicitly opts in?	(Yes/No/Partial)
		Default	Are privacy settings easily accessible, enabling users to review and modify default privacy preferences, where applicable?	(Yes/No/Partial)
6	Data Retention & Disposal	Retention	Are data retention periods defined and documented?	(Yes/No/Partial)
		Retention	Is personal data securely deleted, returned, or anonymized after the defined retention period, and are retention controls automatically enforced where feasible?	(Yes/No/Partial)
		Retention	Is backup data retained and deleted in accordance with the retention policy?	(Yes/No/Partial)
		Retention	Are data disposal activities logged for audit purposes?	(Yes/No/Partial)
		Controls	Is personal data protected using current industry-approved encryption or equivalent security measures during storage and transmission, where applicable?	(Yes/No/Partial)
		Controls	Are Authentication, Authorization, and Accountability (AAA) controls, including role-based access and least-privilege principles, implemented to protect personal data?	(Yes/No/Partial)

		GDPR: Art. 8 • DPDPA: Sec. 9 • HIPAA: 45 CFR Part 164 (where minors' PHI applies) • CCPA/CPRA: §1798.120(c), §1798.121(c) • ISO 27701: A.7.2.8	(Low/Medium/High)	Text
		GDPR: Art. 25(2), Art. 7 • DPDPA: Sec. 6 • HIPAA: 45 CFR §164.508 • CCPA/CPRA: §1798.120, CPRA Consent Requirements • ISO 27701: A.7.2.4	(Low/Medium/High)	Text
		GDPR: Art. 12, Art. 25(2) • DPDPA: Sec. 6, Sec. 8 • HIPAA: N/A* • CCPA/CPRA: §1798.120, §1798.135 • ISO 27701: A.7.3.3	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(e), Art. 13, 30 • DPDPA: Sec. 8(7) • HIPAA: 45 CFR §164.316(b) • CCPA/CPRA: §1798.100 • ISO 27701: A.7.4.3	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(e), Art. 17, Art. 28(3)(g) • DPDPA: Sec. 8(7) • HIPAA: 45 CFR §164.310(d), §164.530(j) • CCPA/CPRA: §1798.105 • ISO 27701: A.7.4.3	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(e), Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.308(a)(7), §164.310(d) • CCPA/CPRA: §1798.100 • ISO 27701: A.7.4.3	(Low/Medium/High)	Text
		GDPR: Art. 5(2), Art. 24, Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.312(b) (Audit Controls) • CCPA/CPRA: Reasonable Security Requirement • ISO 27701: A.7.4.3, A.7.5.1	(Low/Medium/High)	Text
		GDPR: Art. 32, Art. 25 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.312(a), (c), (e) • CCPA/CPRA: Reasonable Security (§1798.150) • ISO 27701: A.7.4.1	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(f), Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.308(a)(4), §164.312(a), (d) • CCPA/CPRA: Reasonable Security • ISO 27701: A.7.4.1	(Low/Medium/High)	Text

Text

Text

Text

Text

Text

Text

Text

Text

Text

7	Privacy Controls (Technical & Organizational)	Controls	Is pseudonymization or anonymization applied, where appropriate?	(Yes/No/Partial)
			Are access to and activities involving personal data logged and monitored?	(Yes/No/Partial)
		Controls	Are audit logs protected from unauthorized access or tampering?	(Yes/No/Partial)
		Controls	Are mechanisms in place to detect, report, and respond to personal data breaches?	(Yes/No/Partial)
		Controls	Are controls implemented to protect the confidentiality, integrity, and availability of personal data?	(Yes/No/Partial)
		Controls	Are temporary files, caches, and session data containing personal data securely managed and removed when no longer required?	(Yes/No/Partial)
		Controls	Are personal data repositories logically or physically segregated where required to reduce privacy and security risks?	(Yes/No/Partial)
		Controls	Are applicable organizational privacy and information security policies considered during the solution design?	(Yes/No/Partial)
		Vendors	Is personal data shared with third parties only when necessary, appropriately authorized, and subject to appropriate contractual and access controls?	(Yes/No/Partial)

		GDPR: Art. 4(5), Art. 25, Art. 32 • DPDPA: Sec. 8 • HIPAA: De-identification Standard (45 CFR §164.514) • CCPA/CPRA: Deidentified Information (§1798.140) • ISO 27701: A.7.4.1	(Low/Medium/High)	Text
		GDPR: Art. 5(2), Art. 24, Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.312(b) • CCPA/CPRA: Reasonable Security • ISO 27701: A.7.5.1	(Low/Medium/High)	Text
		GDPR: Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.312(b), (c) • CCPA/CPRA: Reasonable Security • ISO 27701: A.7.5.1	(Low/Medium/High)	Text
		GDPR: Art. 33, Art. 34 • DPDPA: Sec. 8(6) • HIPAA: 45 CFR §§164.400–414 (Breach Notification Rule) • CCPA/CPRA: §1798.150; California Breach Notification Law • ISO 27701: A.7.5.1	(Low/Medium/High)	Text
		GDPR: Art. 32(1)(b) • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.306(a) • CCPA/CPRA: Reasonable Security • ISO 27701: A.7.4.1	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(e), Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.310(d), §164.312(c) • CCPA/CPRA: Reasonable Security (§1798.150) • ISO 27701: A.7.4.3	(Low/Medium/High)	Text
		GDPR: Art. 25, Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.306, §164.308(a)(4) • CCPA/CPRA: Reasonable Security (§1798.150) • ISO 27701: A.7.4.1	(Low/Medium/High)	Text
		GDPR: Art. 24, Art. 25 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.316 • CCPA/CPRA: Reasonable Security • ISO 27701: A.7.2.1, A.7.4.1	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(c), Art. 6, Art. 28 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.502, §164.504(e) • CCPA/CPRA: §1798.100, §1798.140 • ISO 27701: A.7.2.8	(Low/Medium/High)	Text

Text

Text

Text

Text

Text

Text

Text

Text

Text

8	Third-Party & Vendor Privacy	Vendors	Are appropriate Data Processing Agreements (DPAs) in place with third-party processors, where applicable?	(Yes/No/Partial)
		Vendors	Has the third party been assessed for privacy and security compliance before engagement?	(Yes/No/Partial)
		Vendors	Are appropriate safeguards (e.g., SCCs or equivalent mechanisms) implemented for cross-border personal data transfers, where applicable?	(Yes/No/Partial)
		Vendors	Do third-party agreements include personal data breach notification obligations?	(Yes/No/Partial)
9	Developer Privacy Review	Cookies	Are cookies categorized by purpose and retention period?	(Yes/No/Partial)
		Cookies	Is user consent obtained before placing non-essential cookies or similar tracking technologies?	(Yes/No/Partial)
		API	Are APIs reviewed to ensure only the minimum necessary personal data is collected and shared?	(Yes/No/Partial)
		SDK	Are third-party SDKs reviewed for the personal data they collect, share, request access to, and their compliance with privacy requirements?	(Yes/No/Partial)
		Logs	Do application logs avoid storing unnecessary personal or sensitive data?	(Yes/No/Partial)

		GDPR: Art. 28 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.504(e) (Business Associate Agreements) • CCPA/CPRA: §1798.140, §1798.100(d) • ISO 27701: A.7.2.8	(Low/Medium/High)	Text
		GDPR: Art. 28(1), Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.308(b), §164.504(e) • CCPA/CPRA: Reasonable Security • ISO 27701: A.7.2.8	(Low/Medium/High)	Text
		GDPR: Art. 44–49 • DPDPA: Cross-border Transfer Provisions (as notified by the Central Government) • HIPAA: 45 CFR Part 164 (where applicable) • CCPA/CPRA: Service Provider/Contractor Requirements • ISO 27701: A.7.2.11	(Low/Medium/High)	Text
		GDPR: Art. 28(3)(f), Art. 33 • DPDPA: Sec. 8(6) • HIPAA: 45 CFR §§164.400–414, §164.504(e) • CCPA/CPRA: Reasonable Security & Breach Notification • ISO 27701: A.7.2.8, A.7.5.1	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(b), Art. 5(1)(e), Art. 13 • DPDPA: Sec. 5, Sec. 6 • HIPAA: N/A* • CCPA/CPRA: §1798.100, §1798.135 • ISO 27701: A.7.3.2	(Low/Medium/High)	Text
		GDPR: Art. 6, Art. 7 • DPDPA: Sec. 6 • HIPAA: N/A* • CCPA/CPRA: §1798.120, §1798.135 • ISO 27701: A.7.2.4	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(c), Art. 25 • DPDPA: Sec. 4, Sec. 8 • HIPAA: 45 CFR §164.502(b) • CCPA/CPRA: §1798.100 • ISO 27701: A.7.4.1	(Low/Medium/High)	Text
		GDPR: Art. 25, Art. 28, Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.504(e) • CCPA/CPRA: §1798.140, §1798.100 • ISO 27701: A.7.2.8	(Low/Medium/High)	Text
		GDPR: Art. 5(1)(c), Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.312(b) • CCPA/CPRA: Reasonable Security • ISO 27701: A.7.4.1, A.7.5.1	(Low/Medium/High)	Text

Text

Text

Text

Text

Text

Text

Text

Text

Text

		Testing	Is real (production) personal data prohibited from use in development, testing, and other non-production environments unless approved and appropriately de-identified?	(Yes/No/Partial)
		Consent	Is the consent process tested to ensure consent is properly obtained, recorded, managed, and can be withdrawn, where applicable?	(Yes/No/Partial)
		Review	Is a privacy review included as part of the SDLC approval process before deployment?	(Yes/No/Partial)
10	Ongoing Monitoring & Governance	Monitoring	Are periodic privacy reviews or audits conducted?	(Yes/No/Partial)
		Monitoring	Are changes to the application assessed for privacy impact before implementation?	(Yes/No/Partial)
		Monitoring	Are privacy incidents reviewed and corrective actions implemented?	(Yes/No/Partial)

		GDPR: Art. 25, Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.306, §164.514 • CCPA/CPRA: Reasonable Security • ISO 27701: A.7.4.1	(Low/Medium/High)	Text
		GDPR: Art. 7, Art. 25 • DPDPA: Sec. 6 • HIPAA: 45 CFR §164.508 • CCPA/CPRA: Consent Requirements & Dark Pattern Rules • ISO 27701: A.7.2.4	(Low/Medium/High)	Text
		GDPR: Art. 25 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.308(a)(8) • CCPA/CPRA: Reasonable Security • ISO 27701: A.7.5.1	(Low/Medium/High)	Text
		GDPR: Art. 24, Art. 32 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.308(a)(8) • CCPA/CPRA: Reasonable Security • ISO 27701: A.7.5.1	(Low/Medium/High)	Text
		GDPR: Art. 25, Art. 35 • DPDPA: Sec. 8 • HIPAA: 45 CFR §164.308(a)(1), §164.308(a)(8) • CCPA/CPRA: Risk Assessment Requirements • ISO 27701: A.7.2.5, A.7.4.2	(Low/Medium/High)	Text
		GDPR: Art. 33, Art. 34 • DPDPA: Sec. 8(6) • HIPAA: 45 CFR §§164.400–414 • CCPA/CPRA: Breach Notification & Reasonable Security • ISO 27701: A.7.5.1	(Low/Medium/High)	Text
		GDPR: Art. 24, Art. 25, Art. 32, Art. 35 • DPDPA: Sec. 8		

Text
Text
Text
Text
Text
Text